BTS SIO – OPTION SISR – BLOC 3 – 1re ANNÉE

# Protéger les données à caractère personnel

Thème 1 – Séances 1 et 2 (2 × 2 h)

Données personnelles • RGPD • Risques • Cartographie • Analyse de risques

**Support formateur – corrigés inclus**

Étude de cas FitZone avec corrigé complet, quiz, fiches vierges, repères réglementaires, lexique et FAQ détaillée.

TWAGIRUMUKIZA

Version du 21 octobre 2026

# Cours

### Présentation du cours

Ce support couvre les deux premières séances du Thème 1 (2 × 2 h) : cadre juridique (RGPD) et démarche de gestion des risques. Fil rouge : l'étude de cas FitZone.

| | **Séance 1 (2 h)** | **Séance 2 (2 h)** |
|---|---|---|
| Thème | Données personnelles, principes du RGPD et risques | Analyse de risques et cartographie des données |
| Question directrice | Qu'est-ce qu'on protège, et contre quoi ? | Comment évaluer, prioriser et traiter les risques ? |
| Livrable | Mini-quiz et exercices de qualification | Dossier : cartographie, analyse de risques, plan de prévention |
| Évaluation | Quiz de synthèse | Cas FitZone noté sur 20 |

**Compétences visées** : qualifier une donnée et appliquer les principes du RGPD ; raisonner en sûreté/sécurité et en critères de sécurité ; argumenter les impacts juridiques, financiers et réputationnels ; inventorier un SI et cartographier les données ; conduire une analyse de risques (C = P × G) et proposer un plan de prévention ; analyser un document technique simple.

## Séance 1 – Données personnelles, principes du RGPD et risques

### 1. Définitions

**Donnée à caractère personnel (DCP, art. 4)** : toute information se rapportant à une personne physique identifiée ou identifiable, directement (nom, photo, empreinte) ou indirectement (n° de sécurité sociale, e-mail nominatif, adresse IP, plaque d'immatriculation, recoupement d'informations).

| DCP | Non DCP |
|---|---|
| Nom, e-mail nominatif, adresse IP, matricule, géolocalisation, journaux de connexion liés à un compte | Statistiques réellement anonymisées, chiffre d'affaires, données météo |

> **Point d'examen.** Pseudonymisation (réversible, toujours des DCP, un hash en fait partie) ≠ anonymisation (irréversible, hors RGPD).

**Données sensibles (art. 9)** : origine raciale ou ethnique, opinions politiques, convictions religieuses ou philosophiques, appartenance syndicale, données génétiques, biométriques (identification unique), de santé, vie ou orientation sexuelle. Traitement interdit par principe, sauf exceptions. Les condamnations (art. 10) et le NIR relèvent d'un régime renforcé.

| Terme | Définition |
|---|---|
| Traitement | Toute opération sur des données (collecte, stockage, consultation, transmission, suppression) |
| Responsable de traitement | Détermine les finalités et les moyens |
| Sous-traitant | Traite pour le compte du responsable (hébergeur, paie…) |
| DPO / CNIL | Délégué à la protection des données / autorité de contrôle française |

Le RGPD est applicable depuis le 25 mai 2018 et couvre tout traitement de DCP de personnes situées dans l'UE, y compris par une entreprise hors UE qui les cible.

Une donnée n'est pas personnelle « par nature » : elle l'est par sa capacité à identifier quelqu'un. j.martin@entreprise.fr est personnelle ; contact@entreprise.fr beaucoup moins.

> **Attention.** La localisation, les données financières et les données de mineurs appellent une vigilance particulière. Ne pas confondre « donnée sensible » (RGPD, art. 9) et « information sensible » (valeur pour l'entreprise, séance 2) : un arrêt maladie est une donnée sensible ; une grille tarifaire est une information sensible sans être personnelle.

**Mini-exercice de qualification (5 min)**

Qualifier : (a) l'adresse IP d'un visiteur ; (b) un arrêt maladie dans un dossier RH ; (c) la moyenne de ventes par magasin ; (d) l'empreinte digitale utilisée pour badger ; (e) l'identifiant haché d'un client.

▼ **Corrigé**
(a) DCP · (b) donnée sensible (santé) · (c) non DCP · (d) donnée sensible (biométrie) · (e) DCP (pseudonymisation).

### 2. Principes du RGPD (art. 5) et bases légales (art. 6)

| Principe | Exemple |
|---|---|

| | |
|---|---|
| Licéité, loyauté, transparence | Mention d’information à la collecte |
| Limitation des finalités | Fichier client livré ≠ revendu |
| Minimisation | Pas de date de naissance pour une newsletter |
| Exactitude | Mise à jour des coordonnées |
| Limitation de la conservation | CV non retenus supprimés |
| Intégrité et confidentialité | Chiffrement, droits d’accès, sauvegardes |
| Responsabilité | Registre, politiques, journaux |

**6 bases légales** : consentement, contrat, obligation légale, intérêts vitaux, mission d’intérêt public, intérêt légitime. Un consentement est libre, spécifique, éclairé, univoque et retirable aussi facilement qu’il est donné.

**Art. 32** : mesures techniques et organisationnelles adaptées au risque (chiffrement, pseudonymisation, résilience, tests réguliers). Le RGPD impose une démarche fondée sur le risque, pas un produit. **Art. 25** : privacy by design et by default.

### 3. Typologie des risques

Une **violation de données** (art. 4.12) est une atteinte à la sécurité entraînant, de façon accidentelle ou illicite, la destruction, la perte, l’altération, la divulgation ou l’accès non autorisé à des DCP.

| | **Sûreté** | **Sécurité** |
|---|---|---|
| Contre quoi | Accidents, dysfonctionnements involontaires | Actions malveillantes volontaires |
| Exemples | Panne de disque, erreur, incendie | Ransomware, vol, blocage de service |
| Parades | Sauvegarde, redondance | Contrôle d’accès, correctifs, filtrage |

**4 critères de sécurité** : confidentialité (accès réservé aux personnes autorisées), disponibilité, intégrité, preuve. La preuve repose sur trois éléments : **authentification**, **imputabilité** (un compte = une personne) et **traçabilité** (journaux, horodatage).

**Menaces ANSSI** : déstabilisation (déni de service, défiguration, divulgation), espionnage (point d’eau, spear phishing), sabotage, cybercriminalité (rançongiciel, phishing).

> **Piège.** Un ransomware qui chiffre sans exfiltrer touche d’abord la disponibilité ; avec exfiltration (double extorsion), la confidentialité aussi. Toujours justifier.

**Sûreté et sécurité en détail**

| | **Sûreté** | **Sécurité** |
|---|---|---|
| Exemples | Saturation d’un point d’accès, panne de disque, erreur d’exécution | Blocage d’un service, modification d’informations, vol d’information |
| Quantification | Statistique (durée de vie moyenne d’un disque) | Non quantifiable statistiquement ; on évalue en amont le niveau de risque et les impacts |
| Parades | Sauvegarde, dimensionnement, redondance | Contrôle d’accès, veille sécurité, correctifs, configuration renforcée, filtrage |

Périmètre de la sûreté (menaces non intentionnelles, peu prévisibles) : accidents naturels (orage, inondation, incendie) ; menaces humaines (erreur, maladresse, négligence) ; menaces liées au matériel. Le RGPD ne fait pas la différence : l'atteinte aux données suffit (disque en panne sans sauvegarde, e-mail au mauvais destinataire, ransomware).

**Les 4 critères et la preuve**

| Critère | Définition | Lien RGPD |
|---|---|---|
| Confidentialité | Seules les personnes autorisées ont accès aux données | Art. 5.1.f |
| Disponibilité | Données accessibles rapidement et régulièrement | Art. 32.1.b et c |
| Intégrité | Données consultées non modifiées | Art. 5.1.f |
| Preuve (non-répudiation) | Accès conservés et exploitables | Art. 5.2 ; journalisation |

| Élément de la preuve | Rôle | Exemple |
|---|---|---|
| Authentification | S'assurer de la légitimité de la demande d'accès et accorder les droits associés | Mot de passe, MFA |
| Imputabilité | Attribuer un acte à une personne clairement identifiée | Un compte = une personne |
| Traçabilité | Historique de l'utilisation de la donnée | Journaux d'accès, horodatage |

Ce critère sera réutilisé en séance 6 (chaîne de custody, hash des preuves) et en 2e année (journalisation, SIEM).

**Types de violation selon le critère touché**

| Critère | Type | Exemples | Conséquence pour la personne |
|---|---|---|---|
| Confidentialité | Fuite, accès non autorisé | Base clients exfiltrée ; e-mail au mauvais destinataire ; ordinateur volé non chiffré ; partage cloud public par erreur | Usurpation d'identité, hameçonnage ciblé, atteinte à la vie privée |
| Intégrité | Altération | Modification de notes, dossiers médicaux, coordonnées bancaires | Décisions erronées, fraude, préjudice |
| Disponibilité | Perte, indisponibilité | Ransomware, suppression accidentelle sans sauvegarde, panne prolongée | Impossibilité d'exercer ses droits, soins retardés |

Origines possibles : externes malveillantes (phishing, ransomware, intrusion) ; internes malveillantes (employé qui copie un fichier avant son départ) ; internes accidentelles (erreur humaine, cause très fréquente) ; techniques (panne, bug, mauvaise configuration) ; environnementales (incendie, dégât des eaux).

**Typologie ANSSI en détail**

| Menace | Types d'attaques |
|---|---|
| Déstabilisation | Déni de service (multitude de requêtes) ; défiguration (remplacement de pages pour un message idéologique) ; divulgation de données (exploitation d'une vulnérabilité) |
| Espionnage | Point d'eau (infection du site d'une organisation pour contaminer ses visiteurs) ; spear phishing (usurper une personne connue pour faire ouvrir une pièce jointe malveillante) |

| | |
|---|---|
| Sabotage | Modes d’attaque variés visant à créer une panne sur un périmètre ou sur l’ensemble du SI |
| Cybercriminalité | Rançongiciel (données inaccessibles jusqu’au paiement, chantage à la publication) ; phishing (obtenir des données personnelles, souvent bancaires) |

**Exercice de classement (5 min)**

Classer chaque incident : menace ANSSI + critère touché. (a) Le site de la mairie est remplacé par un message politique. (b) Un faux e-mail « de la DRH » contient un avenant piégé. (c) La base RH est chiffrée contre rançon. (d) Un site de sous-traitant, consulté par vos salariés, a été piégé.

▼ **Corrigé**
(a) déstabilisation (défiguration) / intégrité · (b) espionnage (spear phishing) ou cybercriminalité / confidentialité · (c) cybercriminalité (ransomware) / disponibilité (+ confidentialité si exfiltration) · (d) espionnage (point d’eau) / confidentialité.

### 4. Impacts

| Impact | Contenu |
|---|---|
| Amendes niveau 1 (art. 83) | Jusqu’à 10 M€ ou 2 % du CA mondial (sécurité, notification) |
| Amendes niveau 2 | Jusqu’à 20 M€ ou 4 % du CA mondial (principes, bases légales, droits) ; on retient le plus élevé |
| Civil / pénal | Réparation du préjudice (art. 82) ; code pénal art. 226-16 et suivants |
| Notification | CNIL sous 72 h ; personnes concernées si risque élevé |
| Financier | Remédiation, arrêt d’activité, rançon, cyberassurance, perte de contrats |
| Réputation | Perte de confiance, médiatisation, départ de clients |

Le RGPD raisonne d’abord en risque pour les personnes : usurpation d’identité, discrimination, perte financière, préjudice moral. Repères : Google 50 M€ (2019), Criteo 40 M€ (2023). Elles montrent que les sanctions visent aussi les manquements aux principes, pas seulement les fuites.

**Mesures correctrices** : mise en demeure, injonction, limitation ou interdiction du traitement, publicité de la sanction. **Pénal** : jusqu’à 5 ans d’emprisonnement et 300 000 € d’amende pour les personnes physiques. **Financier** : amendes, frais d’avocats, indemnisation, investigation et restauration, hausse des primes de cyberassurance. **Réputation** : départ vers la concurrence, impact sur la marque et le recrutement, confiance du public pour les collectivités et la santé.

> **Synthèse séance 1.** DCP = information permettant d’identifier une personne ; données sensibles interdites sauf exception. 7 principes, 6 bases légales ; l’art. 32 impose des mesures proportionnées au risque. Sûreté = accidents, sécurité = actions malveillantes. 4 critères dont la preuve. 4 menaces ANSSI. Impacts juridiques, financiers, réputationnels et pour les personnes.

## Séance 2 – Analyse de risques et cartographie

### 1. Imprévu, aléa, risque, problème (NF X50-117)

| Notion | Définition | Exemple |
|---|---|---|
| Imprévu | Futur possible, non identifiable | Nouvelle réglementation en cours de projet |
| Aléa | Identifiable, non quantifiable | Faille inconnue d'un logiciel |
| Risque | Identifiable et quantifiable | Ransomware sur le serveur de fichiers |
| Problème | Dommage déjà réalisé | Le serveur est chiffré |

> Une **faute** est une erreur connue et non corrigée (ex. ne pas mettre à jour après une alerte) : ce n'est plus un risque.

**Test en deux questions** : puis-je identifier l'événement ? Non → imprévu (on ne peut que faire face). Oui → puis-je évaluer ses conséquences ? Non → aléa ; oui → risque. Un risque est une situation problématique qui n'existe pas encore : avec le temps il disparaît ou devient un problème. Un risque n'est pas une faute.

| Étape | Question |
|---|---|
| 1 Description du projet | Qu'est-ce qu'on protège ? (SI, données, organisation) |
| 2 Identification des risques | Que peut-il arriver ? (menaces, vulnérabilités) |
| 3 Priorisation | Qu'est-ce qui est le plus critique ? |
| 4 Stratégie de prévention | Que met-on en place ? |
| 5 Suivi des risques | Où en est-on ? Qu'est-ce qui a changé ? |

Les étapes 1 et 2 s'appuient sur quatre sources : l'environnement du projet, l'existant organisationnel, l'organisation du projet et sa description.

### 2. Inventaire du SI et cartographie

On ne protège bien que ce que l'on connaît. L'inventaire va du métier vers la technique : **actifs primordiaux** (processus, données) → **éléments supports** (applications, OS) → **équipements** (serveurs, postes, mobiles, réseau). Identifiants utiles : adresse MAC, IMEI. Outils : GLPI, OCS Inventory, nmap.

**Classification de l'information** : stratégique (≈ 5 %), sensible (≈ 15 %), divulgable (≈ 80 %). Ne pas confondre avec les données sensibles de l'art. 9.

**Réseaux** : BAN (corps), PAN (personne, < 10 m), LAN (local), MAN (ville), CAN (campus), WAN (étendu, Internet). Chaque interconnexion est un flux à cartographier.

**Fiche de cartographie** : traitement/finalité, données, sensibles ?, personnes, supports, accès, durée de conservation, sous-traitants. Elle alimente le registre des traitements (art. 30).

| Niveau | Contenu | Exemples |
|---|---|---|
| Actifs primordiaux | Processus métiers et données | Gestion des abonnements, paie, données de santé |

| | | |
|---|---|---|
| Éléments supports | Applications, systèmes d'exploitation | Logiciel de gestion v4.2, Windows Server, Android |
| Équipements | Matériel | Smartphones, tablettes, commutateurs, routeurs/box, serveurs, ordinateurs |

À identifier : les **données sensibles** (mots de passe, cartes de crédit, documents personnels, plan marketing, fichier client, brevets, contrats), les **applications et leur version**, les **systèmes d'exploitation** (Android, iOS, Windows, Linux, macOS), les **équipements**. Outils de découverte : ServiceNow, HP OpenView, GLPI, OCS Inventory, nmap (séance Kali). Recensement des logiciels et versions : Everest. Les actifs primordiaux correspondent aux traitements du registre ; supports et équipements aux supports de la fiche.

**Classification de l'information**

| Catégorie | Définition | Part |
|---|---|---|
| Stratégique | Met à nu la valeur ajoutée de l'entreprise ou divulgue ses avantages compétitifs | ≈ 5 % |
| Sensible | Données qui, associées, peuvent révéler une partie de l'information stratégique | ≈ 15 % |
| Divulgable | Diffusable à l'extérieur sans préjudice | ≈ 80 % |

**Exercice de classification (10 min)**

Pour chaque information de l'entreprise, choisissez une catégorie, puis les services autorisés à y accéder (plusieurs réponses possibles).

| Information | Divulgable | Sensible | Stratégique | Accès autorisé pour |
|---|---|---|---|---|
| Contacts et dossiers du personnel | ☐ | ☐ | ☐ | |
| Factures clients | ☐ | ☐ | ☐ | |
| Factures fournisseurs | ☐ | ☐ | ☐ | |
| Listes fournisseurs | ☐ | ☐ | ☐ | |
| Données comptables | ☐ | ☐ | ☐ | |
| Relevés de compte | ☐ | ☐ | ☐ | |
| Propositions commerciales | ☐ | ☐ | ☐ | |
| Contrats commerciaux | ☐ | ☐ | ☐ | |
| Contrats de travail | ☐ | ☐ | ☐ | |
| Données de production | ☐ | ☐ | ☐ | |
| Grille tarifaire des produits | ☐ | ☐ | ☐ | |
| Procédés de fabrication | ☐ | ☐ | ☐ | |
| Veille concurrentielle | ☐ | ☐ | ☐ | |

Ne pas confondre « information sensible » (valeur pour l'entreprise) et « donnée sensible » (RGPD, art. 9). Un dossier du personnel peut être les deux.

**Réseaux et interconnexions**

| Sigle | Nom | Caractéristique |
|---|---|---|

| | | |
|---|---|---|
| BAN | Body Area Network | Télétransmetteurs dans le domaine de la santé |
| PAN / WPAN | Personal Area Network | Centré sur une personne, moins de 10 m ; IrDA, ZigBee, Bluetooth, Wireless USB |
| LAN | Local Area Network | Réseau local, plusieurs périphériques et individus |
| MAN | Metropolitan Area Network | Plus large qu'un LAN, par exemple une ville |
| CAN | Campus Area Network | Plusieurs LAN, taille d'une université |
| WAN | Wide Area Network | Étendue nationale ou internationale (Internet) |

Points d'interconnexion à maîtriser : accès Internet par box (ADSL, fibre) ou 4G-5G ; interconnexion avec partenaires, prestataires, universités : liaison dédiée (E1/T1, fibre noire), VPN sur WAN d'opérateur ou Internet, liaison satellite. Chaque interconnexion est un flux à cartographier (sous-traitant, éventuellement hors UE).

**Fiche de cartographie : exemple rempli**

| Traitement | Données | Sensibles ? | Personnes | Support | Accès | Durée | Sous-traitant |
|---|---|---|---|---|---|---|---|
| Gestion de la paie | Identité, RIB, NIR | NIR (régime renforcé) | Salariés | Serveur RH + SaaS paie | RH, compta | 5 ans | Éditeur paie |

**Méthode en 4 étapes** : (1) lister les traitements par service ; (2) décrire chacun avec le tableau (traitement, catégories de données, personnes, supports et lieux, acteurs et accès, flux, durée de conservation, mesures existantes) ; (3) représenter les flux (source → système → destinataire) ; (4) repérer les points sensibles : données sensibles, transferts hors UE, accès excessifs, absence de durée de conservation.

### 3. Prioriser : criticité et matrice 5 × 5

**Criticité C = Probabilité P × Gravité G**, cotées de 1 à 5. Vocabulaire : actif, menace, vulnérabilité, événement redouté, risque résiduel.

| Criticité | Niveau | Action |
|---|---|---|
| 1 – 4 | Faible | Acceptable |
| 5 – 9 | À surveiller | Sous le seuil |
| 10 – 14 | À traiter | Seuil atteint : action obligatoire |
| 15 – 25 | Prioritaire | Traitement immédiat |

Exemple : P = 4, G = 3 → C = 12, au-dessus du seuil. **Quatre zones** : risques perturbateurs (à supprimer), négligeables, de gravité (on « vit avec »), intolérables (projet refusé ou modifié).

> Nuance RGPD : pour la santé ou la biométrie, un risque très grave pour les personnes, même peu probable, impose des mesures renforcées et souvent une AIPD (art. 35).

**AMDEC** : criticité = fréquence × gravité × indéterminabilité (probabilité de ne pas détecter l'incident). **4 traitements** : réduire, éviter, transférer, accepter.

| Niveau | Probabilité | Gravité |
|---|---|---|

| | | |
|---|---|---|
| 1 | Très improbable | Négligeable |
| 2 | Peu probable | Limitée |
| 3 | Possible | Importante |
| 4 | Probable | Très importante |
| 5 | Quasi certaine | Critique / catastrophique |

Variante à 4 niveaux (RGPD / EBIOS) : 1 négligeable, 2 limité, 3 important, 4 maximal. Rester cohérent avec l'échelle de l'énoncé.

**Matrice 5 × 5** (seuil d'acceptabilité : criticité ≥ 10). Principe de Pareto : 20 % des causes produisent 80 % des effets, on concentre l'effort sur les criticités les plus élevées.

| G \ P | 1 | 2 | 3 | 4 | 5 |
|---|---|---|---|---|---|
| **5** | **5** | **10** | **15** | **20** | **25** |
| **4** | **4** | **8** | **12** | **16** | **20** |
| **3** | **3** | **6** | **9** | **12** | **15** |
| **2** | **2** | **4** | **6** | **8** | **10** |
| **1** | **1** | **2** | **3** | **4** | **5** |

| Zone | Profil | Que faire ? |
|---|---|---|
| Risques perturbateurs | Très probables, gravité très faible | Ce sont des problèmes : supprimer les causes, sinon perturbations régulières |
| Négligeables | Très peu probables, impact minimal | Ne pas en tenir compte |
| De gravité | Dramatiques mais très peu probables (météorite, pandémie) | On « vit avec » : parade pas toujours possible |
| Intolérables | Très probables et extrêmement graves | Projet inacceptable en l'état : réduire la criticité, modifier le projet ou refuser |

> La règle « ne pas tenir compte des risques de gravité » vaut pour les risques de projet, pas pour les droits et libertés des personnes.

| Option | Principe | Exemple |
|---|---|---|
| Réduire | Mesures de sécurité (le plus fréquent) | MFA, sauvegarde hors ligne, chiffrement |
| Éviter | Supprimer le traitement ou l'activité à risque | Ne plus collecter l'empreinte digitale |
| Transférer | Assurance, sous-traitance encadrée par contrat | Cyberassurance, hébergeur certifié |
| Accepter | Risque résiduel assumé et documenté | Risque faible sous le seuil, validé par la direction |

Deux leviers pour réduire un risque : limiter la probabilité qu'il devienne un problème (prévention) et réduire l'impact s'il se réalise (protection, réparation). L'indéterminabilité de l'AMDEC justifie la détection (journaux, IDS, SIEM, vus en 2e année).

### 4. Prévention et plan de prévention

L'attaquant n'a besoin que d'une faille ; le défenseur doit couvrir tout le système. D'où la **défense en profondeur** : politique et procédures → sécurité physique → DMZ/périmètre → réseau interne → machine → application → donnée.

Le **plan de prévention** synthétise l'analyse : pour chaque risque, un responsable, la prévention (✔/✘), la réparation (✔/✘) et un état (vert, orange, rouge). Un risque sans prévention ni réparation est le plus dangereux. Le suivi se fait à chaque comité : on réidentifie, recote et met à jour (art. 24 et 32).

| Couche | Mesures |
|---|---|
| Politique, procédures | Politique de sécurité, procédure de secours, sensibilisation |
| Sécurité physique | Gardiens, verrous, contrôle d'accès |
| DMZ / périmètre | Pare-feu, VPN, zone démilitarisée |
| Réseau interne | Sous-réseaux, NIDS, VLAN |
| Machine | Antivirus, correctifs, HIDS, authentification |
| Application | Contrôle des entrées, test d'intrusion, communications chiffrées (HTTPS, SSH), traçabilité |
| Donnée | Chiffrement, mots de passe, droits d'accès par fichier/répertoire |

Objectifs : prévenir, bloquer, limiter, détecter, alerter, réagir, réparer. Ce schéma sera repris en 2e année (DMZ, VLAN, Zero Trust).

#### Exemple de plan de prévention

| Risque | P | G | C | Responsable | Prévention | Réparation | État |
|---|---|---|---|---|---|---|---|
| A | 4 | 4 | 16 | Resp. SI | ✔ | ✘ | Orange |
| B | 3 | 3 | 9 | DPO | ✘ | ✔ | Orange |
| C | 2 | 3 | 6 | Resp. RH | ✔ | ✔ | Vert |
| D | 4 | 5 | 20 | DSI | ✘ | ✘ | Rouge |

Un risque sans prévention ni réparation (✘ ✘) est le plus dangereux. Le responsable suit le risque, vérifie les actions et déclenche la réparation si le risque devient un problème.

#### Analyser un tableau de risques (type examen)

Format : menace → vulnérabilité → actif et impact → risque → recommandation.

| Menace | Vulnérabilité | Actif et impact | Risque | Recommandation |
|---|---|---|---|---|
| Surchauffe de la salle serveurs (élevée) | Climatisation de 10 ans (élevée) | Serveurs : tous services indisponibles (critique) ; ≈ 45 000 € par occurrence | Élevé | Remplacer le climatiseur (≈ 2 700 €) |
| Attaque DDoS (élevée) | Pare-feu bien configuré (faible) | Site web indisponible (critique) ; ≈ 8 900 € par heure | Moyen | Surveiller le pare-feu |
| Inondation (moyenne) | Salle serveurs au 2e étage (faible) | Serveurs indisponibles (critique) | Faible | Aucune action |

| | | | | |
|---|---|---|---|---|
| Suppression accidentelle de fichiers (élevée) | Droits corrects, audit, sauvegardes (faible) | Partage de fichiers : restaurables (moyen) | Faible | Surveiller droits, comptes privilégiés, sauvegardes |

> Le risque dépend de la combinaison menace × vulnérabilité × impact : une menace élevée (DDoS) devient un risque moyen grâce à une faible vulnérabilité ; une menace banale + vulnérabilité élevée + actif critique = risque élevé (climatisation).

**Variante : scénarios de menace** (vraisemblance sur 4 niveaux). Exemple : attaquant extérieur, espionnage, ordinateur de l'opérateur, vraisemblance 2 – limité (données uniquement sur le serveur de base de données) ; conséquence sur la confidentialité : l'authentification n'est plus assurée aux seules personnes habilitées.

**Suivre les risques** : revoir le plan à chaque réunion d'étape ou comité de pilotage ; à chaque modification significative, réidentifier, recoter et définir de nouvelles actions (reprise des étapes 2 à 4) ; l'utiliser comme outil de reporting et de pilotage. Exigence des art. 24 et 32 et de la responsabilité (art. 5.2).

### 5. Étude de cas FitZone (corrigé résumé)

3 salles de sport, 45 salariés, environ 6 000 abonnés. Constats : certificats médicaux dans un dossier ouvert à tous, sauvegarde USB branchée en permanence, empreinte digitale pour les abonnés premium, caméras dans les vestiaires conservées « jusqu'à saturation », WhatsApp personnel pour des objectifs de santé, mot de passe admin *fitzone2019* partagé.

| Réf. | Événement redouté | Critère | P | G | C | Niveau |
|---|---|---|---|---|---|---|
| R1 | Fuite des certificats médicaux | Confidentialité | 4 | 5 | 20 | Prioritaire |
| R2 | Ransomware sur serveur et sauvegarde USB | Disponibilité | 4 | 4 | 16 | Prioritaire |
| R3 | Diffusion d'images des vestiaires | Confidentialité | 3 | 4 | 12 | À traiter |
| R4 | Modification d'IBAN sans auteur identifiable | Intégrité + preuve | 3 | 4 | 12 | À traiter |
| R5 | Fuite des empreintes digitales | Confidentialité | 2 | 5 | 10 | À traiter |
| R6 | Panne disque sans sauvegarde valide | Disponibilité | 3 | 3 | 9 | À surveiller |

**Mesures clés** : droits par groupe et attestation d'aptitude au lieu du certificat (minimisation) ; sauvegarde 3-2-1 avec copie hors ligne et test de restauration ; retrait des caméras des vestiaires et durée de conservation ; comptes nominatifs et journalisation ; alternative badge et AIPD pour la biométrie ; registre, référent RGPD, contrats sous-traitants, charte d'usage.

> Le mot de passe partagé n'est pas un risque : c'est une faute et un problème, à corriger immédiatement.

**Contexte**

FitZone : réseau de 3 salles de sport (45 salariés, environ 6 000 abonnés). Vous êtes technicien SISR chez le prestataire ; le dirigeant demande « de voir où on en est avec le RGPD ». Constats : logiciel de gestion sur un serveur dans l'arrière-boutique (identité, adresse, e-mail, téléphone, IBAN, certificat médical scanné, photo) ; badge d'accès avec lecteur d'empreinte digitale pour les abonnés premium ; certificats médicaux dans un dossier partagé \\SRV\Abonnes accessible à tous les salariés ; sauvegarde sur un disque USB branché en permanence ; newsletter via un outil en ligne avec d'anciens abonnés partis il y a plus de 8 ans ; coaches avec smartphone personnel et groupe WhatsApp (noms et objectifs de santé) ; vidéosurveillance à l'accueil et dans les vestiaires, conservée « jusqu'à saturation du disque » ; Wi-Fi d'accueil partagé avec l'administration ; mot de passe admin fitzone2019 connu de tous.

**Travail demandé (35 à 45 min)**

| Partie | Durée | Travail |
|---|---|---|
| A – Cartographie | 10 min | Compléter la fiche ; inventaire en 3 niveaux ; classer 5 informations |
| B – Analyse de risques | 15 min | 5 événements redoutés (un par critère dont la preuve), menace ANSSI, P et G sur 5, C = P × G, matrice |
| C – Plan de prévention | 10 min | Pour les 5 risques les plus critiques : mesure (couche), responsable, prévention, réparation, état |

Livrable : 2 à 3 pages. Barème /20 : cartographie et inventaire 4 ; événements, cotation et calcul 6 ; mesures reliées aux principes RGPD et couches de défense 6 ; clarté et présentation 4.

**Corrigé A : cartographie**

| Traitement | Données | Sensibles ? | Support / accès | Problèmes relevés |
|---|---|---|---|---|
| Gestion des abonnements | Identité, coordonnées, IBAN, photo | Non (financières : vigilance) | Serveur local ; tous les salariés | Accès non limité ; compte admin partagé |
| Suivi d'aptitude médicale | Certificat médical | Oui – santé | Dossier partagé ouvert à tous | Base légale / consentement explicite à vérifier ; accès trop large ; minimisation (une attestation suffit) |
| Contrôle d'accès biométrique | Empreinte digitale | Oui – biométrie | Lecteur + base | Régime strict ; alternative badge ; AIPD probable |
| Newsletter | Nom, e-mail | Non | Outil en ligne (sous-traitant) | Conservation excessive ; contrat sous-traitant ; consentement |
| Vidéosurveillance | Images | Non en soi | Disque local | Vestiaires disproportionné ; durée non définie ; affichage |
| Communication des coaches | Noms, objectifs de santé | Oui – santé | WhatsApp, smartphones personnels | Hors contrôle de l'entreprise ; transfert possible hors UE |

**Inventaire** – Actifs primordiaux : gestion des abonnements, suivi d'aptitude médicale, contrôle d'accès biométrique, vidéosurveillance, newsletter. Supports : logiciel de gestion, outil de newsletter, WhatsApp, système du lecteur d'empreinte. Équipements : serveur de l'arrière-boutique, disque USB, smartphones des coaches, caméras, lecteur d'empreinte, Wi-Fi d'accueil.

**Corrigé B : vulnérabilités et menaces**

R1 : menace cybercriminalité / erreur interne ; vulnérabilité : dossier ouvert à tous, pas de chiffrement. R2 : cybercriminalité ; sauvegarde connectée en permanence, mot de passe faible, Wi-Fi partagé (disponibilité + confidentialité). R3 : malveillance interne ; visionnage libre, durée illimitée. R4 : fraude interne ; compte administrateur partagé, aucune journalisation. R5 : espionnage / cybercriminalité ; données irremplaçables (non révocables). R6 : sûreté (accident) ; aucun test de restauration.

> Le défaut de mise à jour du logiciel de gestion (P = 5, G = 2, C = 10) est un risque perturbateur : on supprime la cause plutôt que de l'« accepter ».

**Corrigé C : plan de prévention (extrait)**

| Risque | C | Mesure (couche) | Responsable | Prév. | Répar. | État |
|---|---|---|---|---|---|---|
| R1 Fuite certificats | 20 | Droits par groupe, chiffrement, ne conserver qu'une attestation (Donnée) – minimisation | Direction + prestataire SISR | ✘ à faire | ✘ procédure de notification 72 h | Rouge |
| R2 Ransomware | 16 | Sauvegarde 3-2-1 hors ligne ou immuable, test de restauration, MFA, Wi-Fi séparé (Réseau, Machine) | Prestataire SISR | ✘ à faire | ✘ plan de restauration | Rouge |
| R3 Vestiaires | 12 | Retirer les caméras, fixer une durée, afficher l'information (Politique) | Direction | ✘ à faire | – | Orange |
| R4 Modification d'IBAN | 12 | Comptes nominatifs, mots de passe robustes, journalisation (Application, Preuve) | Direction | ✘ à faire | ✔ si logs exploitables | Orange |
| R5 Empreintes | 10 | Alternative badge, consentement explicite, AIPD, chiffrement des gabarits | DPO / référent RGPD | ✘ à faire | ✘ | Orange |

Gouvernance : supprimer les contacts inactifs et définir des durées de conservation (art. 5.1.e) ; cesser les échanges de données de santé sur WhatsApp personnel, utiliser un outil validé et une charte ; tenir un registre ; désigner un référent RGPD ; encadrer les sous-traitants par contrat ; sensibiliser le personnel.

**Synthèse séance 2, conseils d'épreuve et repères**

**Synthèse** : risque identifiable et quantifiable, faute = erreur non corrigée ; 5 étapes ; inventaire métiers → applications → équipements ; C = P × G, seuil ≥ 10 ; 4 zones ; défense en profondeur ; plan de prévention mis à jour en continu ; risque élevé pour les personnes → AIPD (art. 35).

**Conseils pour l'épreuve** : citer l'article ou le principe RGPD ; raisonner en critères (C, D, I, preuve) et impact sur les personnes ; toujours justifier (événement redouté → vulnérabilité → mesure) ; proposer des mesures proportionnées, techniques et organisationnelles plutôt qu'une liste d'outils ; présenter en tableaux.

**Note formateur** : dans le support « Analyse des risques », la pyramide de l'information affiche 5 % / 15 % / 80 % dans le texte mais 85 % sur le schéma ; seul 80 % fait 100 %.

**Annexe D – Repères réglementaires**

| Article | Objet |
|---|---|
| 4 | Définitions (DCP, traitement, violation) |
| 5 | Principes |
| 6 | Bases légales |
| 9 et 10 | Catégories particulières ; condamnations pénales |
| 24 | Responsabilité du responsable de traitement |
| 25 | Protection dès la conception et par défaut |
| 30 | Registre des activités de traitement |
| 32 | Sécurité du traitement |

| | |
|---|---|
| 33 et 34 | Notification à la CNIL (72 h) et aux personnes |
| 35 | AIPD |
| 82 et 83 | Droit à réparation ; amendes |

## Annexes A–C : fiches vierges

### Annexe A – Fiche de cartographie des traitements

| Traitement / finalité | Données | Sensibles ? | Personnes | Support | Accès | Durée | Sous-traitant |
|---|---|---|---|---|---|---|---|
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |

### Annexe B – Tableau d’analyse de risques

| Réf. | Événement redouté | Critère | Menace | Vulnérabilité | P | G | C = P×G | Niveau |
|---|---|---|---|---|---|---|---|---|
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |

### Annexe C – Plan de prévention

| Risque | C | Mesure(s) et couche de défense | Responsable | Prévention ✔/✘ | Réparation ✔/✘ | État |
|---|---|---|---|---|---|---|
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |

# Lexique

### Lexique

Par ordre alphabétique ; « Réf. » renvoie à la séance où la notion est introduite.

| Terme | Définition | Réf. |
|---|---|---|
| **Actif (bien)** | Ce qu'il faut protéger : données, processus métiers, applications, équipements. | S2 |
| **AIPD (DPIA)** | Analyse d'impact relative à la protection des données (art. 35), obligatoire quand un traitement présente un risque élevé pour les droits et libertés (biométrie, santé à grande échelle, surveillance…). | S2 |
| **Aléa** | Événement futur possible, identifiable mais non quantifiable (NF X50-117). | S2 |
| **AMDEC** | Analyse des modes de défaillance, de leurs effets et de leur criticité : fréquence × gravité × indéterminabilité. | S2 |
| **Anonymisation** | Processus irréversible rendant l'identification impossible ; les données anonymisées sortent du champ du RGPD. | S1 |
| **ANSSI** | Agence nationale de la sécurité des systèmes d'information ; publie la typologie des 4 menaces : déstabilisation, espionnage, sabotage, cybercriminalité. | S1 |
| **Authentification** | Vérification de la légitimité d'une demande d'accès (mot de passe, MFA, certificat). Un des trois éléments de la preuve. | S1 |
| **BAN / PAN / LAN / MAN / CAN / WAN** | Réseaux selon leur étendue : corps, personne, local, métropolitain, campus, étendu (Internet). | S2 |
| **Base légale** | Fondement juridique d'un traitement (art. 6) : consentement, contrat, obligation légale, intérêts vitaux, mission d'intérêt public, intérêt légitime. | S1 |
| **Cartographie des données** | Recensement des traitements, données, supports, accès, flux et durées de conservation. Base du registre (art. 30). | S2 |
| **Chaîne de custody** | Suivi documenté de la conservation d'une preuve numérique (qui, quand, comment), avec empreintes (hash). Vue en séance 6. | S1 |
| **CNIL** | Commission nationale de l'informatique et des libertés : autorité de contrôle française du RGPD. | S1 |
| **Confidentialité** | Seules les personnes autorisées ont accès aux données. Critère de sécurité. | S1 |
| **Consentement** | Manifestation de volonté libre, spécifique, éclairée et univoque, retirable à tout moment. | S1 |
| **Criticité (C)** | Niveau d'un risque : C = Probabilité × Gravité, comparée à un seuil d'acceptabilité. | S2 |
| **Cybercriminalité** | Menace ANSSI regroupant notamment le rançongiciel et l'hameçonnage. | S1 |
| **DCP** | Donnée à caractère personnel : toute information se rapportant à une personne physique identifiée ou identifiable (art. 4). | S1 |
| **Défense en profondeur** | Plusieurs lignes de défense indépendantes et autonomes ; la perte d'une ligne conduit à un niveau de défense plus fort. | S2 |
| **Déni de service (DoS / DDoS)** | Attaque saturant un service par une multitude de requêtes pour le rendre indisponible. DDoS : depuis de nombreuses sources. | S1 |

| | | |
|---|---|---|
| **Disponibilité** | Les données sont accessibles rapidement et régulièrement. Critère de sécurité. | S1 |
| **DMZ** | Zone démilitarisée : segment réseau intermédiaire entre Internet et le réseau interne, où l'on place les services exposés. Approfondie en 2e année. | S2 |
| **Données sensibles** | Catégories particulières (art. 9) : santé, biométrie, génétique, origine, opinions politiques, religion, syndicat, vie sexuelle. Traitement interdit sauf exception. | S1 |
| **Double extorsion** | Ransomware qui chiffre et exfiltre les données, avec menace de publication. | S1 |
| **DPO / DPD** | Délégué à la protection des données : conseille, contrôle la conformité, point de contact de la CNIL et des personnes. | S1 |
| **EBIOS RM** | Méthode d'analyse de risques de l'ANSSI (ateliers, gravité, vraisemblance, scénarios). Approfondie en 2e année. | S2 |
| **Événement redouté** | Atteinte à un critère de sécurité qu'on cherche à éviter (fuite, altération, indisponibilité, absence de preuve). | S2 |
| **Faute** | Erreur non corrigée (ex. ne pas appliquer un correctif après une alerte). Ce n'est plus un risque. | S2 |
| **Gravité (G)** | Ampleur des conséquences si le risque se réalise. | S2 |
| **Hameçonnage (phishing)** | Tromper un utilisateur pour obtenir des données personnelles ou bancaires (courriel, SMS, réseaux sociaux). Variante ciblée : spear phishing. | S1 |
| **Imprévu** | Événement futur possible, non identifiable. Positif ou négatif. | S2 |
| **Imputabilité** | Possibilité d'attribuer un acte à une personne clairement identifiée (un compte = une personne). | S1 |
| **Information divulgable / sensible / stratégique** | Classification de l'information selon sa valeur pour l'entreprise (≈ 80 % / 15 % / 5 %). À ne pas confondre avec les données sensibles du RGPD. | S2 |
| **Intégrité** | Assurance que les données consultées n'ont pas été modifiées. Critère de sécurité. | S1 |
| **Menace** | Source potentielle de dommage : pirate, employé, panne, sinistre. | S2 |
| **Minimisation** | Ne collecter que les données nécessaires à la finalité (art. 5.1.c). | S1 |
| **NIR** | Numéro d'inscription au répertoire (sécurité sociale). Régime de protection renforcé. | S1 |
| **Non-répudiation (preuve)** | Impossibilité pour l'auteur d'un acte de le nier : authentification + imputabilité + traçabilité. | S1 |
| **Notification de violation** | Information de la CNIL sous 72 h (art. 33) et, si le risque est élevé, des personnes concernées (art. 34). | S1 |
| **Plan de prévention** | Synthèse de l'analyse de risques : actions de prévention et de réparation, responsable, suivi. | S2 |
| **Privacy by design / by default** | Protection des données dès la conception / par défaut (art. 25). | S1 |
| **Probabilité (P)** | Chance qu'un risque devienne un problème (aussi vraisemblance ou fréquence). | S2 |
| **Problème** | Événement dommageable déjà réalisé, à résoudre. | S2 |
| **Pseudonymisation** | Remplacement d'identifiants par un pseudonyme ; réversible avec une clé, donc toujours des DCP. | S1 |
| **Ransomware (rançongiciel)** | Logiciel qui rend les données inaccessibles (chiffrement) jusqu'au paiement d'une rançon. | S1 |

| | | |
|---|---|---|
| **Registre des traitements** | Document recensant les traitements de DCP (art. 30) : finalités, catégories de données, destinataires, durées, mesures. | S2 |
| **Responsable de traitement (RT)** | Organisme qui détermine les finalités et les moyens du traitement. | S1 |
| **Risque** | Événement futur possible, identifiable et quantifiable. Peut disparaître ou devenir un problème. | S2 |
| **Risque résiduel** | Risque restant après application des mesures ; il doit être accepté et documenté. | S2 |
| **Sabotage** | Menace ANSSI visant à provoquer une panne sur un périmètre ou sur l'ensemble du SI. | S1 |
| **Sécurité** | Protection contre les actions malveillantes volontaires. | S1 |
| **Seuil d'acceptabilité** | Criticité à partir de laquelle des actions préventives sont obligatoires (ici ≥ 10 sur 25). | S2 |
| **Sous-traitant** | Traite des données pour le compte du RT ; encadré par un contrat (art. 28). | S1 |
| **Sûreté** | Protection contre les dysfonctionnements et les accidents involontaires. | S1 |
| **Traitement** | Toute opération sur des données : collecte, stockage, consultation, transmission, suppression… | S1 |
| **Traçabilité** | Historique de l'utilisation d'une donnée (journaux d'accès, horodatage). | S1 |
| **Violation de données** | Atteinte à la sécurité entraînant destruction, perte, altération, divulgation ou accès non autorisé à des DCP (art. 4.12). | S1 |
| **VPN** | Réseau privé virtuel : tunnel chiffré sur un réseau d'opérateur ou sur Internet. | S2 |
| **Vulnérabilité** | Faiblesse exploitable : mot de passe faible, absence de MFA, correctif manquant, pas de sauvegarde. | S2 |
| **Watering hole (point d'eau)** | Infection du site d'une organisation pour contaminer les ordinateurs de ses visiteurs. | S1 |

# FAQ détaillée

**FAQ détaillée**

Les questions que posent le plus souvent les étudiants et les jurys, regroupées par thème.

**A. RGPD et données personnelles**

**▼ Q1. Une adresse IP est-elle toujours une donnée personnelle ?**

En pratique oui : elle peut identifier une personne, notamment en la recoupant avec les données d'un fournisseur d'accès ; même une IP dynamique peut l'être si l'organisme dispose de moyens légaux d'identification. À l'examen : « oui, identification indirecte », et le justifier.

**▼ Q2. Quelle différence entre anonymisation et pseudonymisation ? Un hash est-il anonyme ?**

L'anonymisation est irréversible et sort du RGPD. La pseudonymisation reste réversible (clé, table de correspondance, recoupement) : ce sont toujours des DCP. Un hash d'e-mail ou de téléphone est une pseudonymisation : il suffit de hacher une liste de candidats pour retrouver l'original. C'est une mesure de sécurité utile (art. 32), pas une sortie du RGPD.

**▼ Q3. Une adresse e-mail professionnelle est-elle une donnée personnelle ?**

Oui si elle identifie une personne (prenom.nom@entreprise.fr) : le RGPD protège la personne physique, y compris dans son cadre professionnel. Une adresse générique (contact@) l'est beaucoup moins. Les personnes morales ne sont pas protégées.

**▼ Q4. Le consentement est-il obligatoire pour tout traitement ?**

Non, c'est une des six bases légales. La paie s'appuie sur le contrat et l'obligation légale ; une livraison sur l'exécution du contrat. Le consentement est surtout requis pour la prospection par certains canaux, les cookies non essentiels ou, explicite, certaines données sensibles. Entre employeur et salarié, il est rarement considéré comme « libre ».

**▼ Q5. Quelle différence entre responsable de traitement et sous-traitant ?**

Le responsable décide de la finalité et des moyens essentiels ; le sous-traitant agit sur instruction, pour son compte (hébergeur, paie, SaaS), dans un cadre contractuel (art. 28). FitZone est responsable ; l'éditeur de newsletter est sous-traitant ; le prestataire SISR peut l'être dès qu'il accède aux données.

**▼ Q6. L'organisme doit-il obligatoirement désigner un DPO ?**

Obligatoire pour les autorités et organismes publics, pour ceux dont l'activité exige un suivi régulier et systématique des personnes à grande échelle, et pour ceux qui traitent des données sensibles à grande échelle (art. 37). Sinon facultatif mais recommandé : on désigne souvent un référent RGPD.

**▼ Q7. Le registre des traitements est-il obligatoire pour une petite structure ?**

En principe oui. La dérogation de l'art. 30 (moins de 250 salariés) ne s'applique pas si le traitement n'est pas occasionnel, présente un risque ou porte sur des données sensibles. FitZone (45 salariés, santé et biométrie) doit en tenir un.

**B. Violations de données et sanctions**

**▼ Q8. À partir de quand court le délai de 72 heures ? Les week-ends comptent-ils ?**

Il court dès que le responsable a pris connaissance de la violation (avec un degré raisonnable de certitude) et inclut week-ends et jours fériés. La notification peut se faire par étapes ; au-delà de 72 h, il faut justifier. Le sous-traitant avertit le responsable « dans les meilleurs délais ».

**▼ Q9. Faut-il notifier toutes les violations de données ?**

Non : pas de notification à la CNIL si la violation n'est pas susceptible d'engendrer un risque pour les personnes (art. 33), mais toute violation est documentée dans un registre interne. L'information des personnes (art. 34) n'est exigée que si le risque est élevé (ex. données de santé ou bancaires non chiffrées).

**▼ Q10. Un ransomware est-il une violation si rien n'a été volé ?**

Oui : la perte de disponibilité est une violation. Si les données ont aussi été copiées (double extorsion), il y a en plus atteinte à la confidentialité. La notification dépend du risque pour les personnes (soins retardés, droits impossibles à exercer).

**▼ Q11. Les amendes de 10 M€ et 20 M€ sont-elles automatiques ?**

Non, ce sont des plafonds. La CNIL tient compte de la gravité, de la durée, du caractère intentionnel, des mesures pour limiter le dommage, de la coopération et de la taille de l'organisme. On retient le plus élevé entre le montant fixe et le pourcentage du CA mondial. Beaucoup de sanctions de PME sont bien inférieures.

**▼ Q12. Combien de temps conserver les images de vidéosurveillance ?**

Ce sont des DCP. La CNIL recommande quelques jours, sans dépasser un mois. Les personnes sont informées par affichage, l'accès est limité, et les caméras dans les lieux intimes (vestiaires, toilettes) sont en principe disproportionnées. « Jusqu'à saturation du disque » n'est pas une durée : c'est un manquement à la limitation de la conservation.

**▼ Q13. Pourquoi l'empreinte digitale pose-t-elle problème pour contrôler l'accès ?**

C'est une donnée biométrique : sensible et non révocable. Il faut justifier la nécessité, proposer une alternative (badge), recueillir un consentement explicite dans une relation client, chiffrer les gabarits, et le plus souvent réaliser une AIPD.

**▼ Q14. Pourquoi ne pas conserver le certificat médical complet d'un abonné ?**

Minimisation : l'organisme a besoin de savoir que la personne est apte, pas de connaître son état de santé. On conserve apte/inapte et la date de validité plutôt que la copie, qui est une donnée de santé. Moins on conserve, moins la fuite potentielle est grave.

### C. Analyse de risques

**▼ Q15. Menace, vulnérabilité, événement redouté, risque : comment les distinguer ?**

La menace est la source (pirate, employé négligent, panne) ; la vulnérabilité la faiblesse exploitable (mot de passe partagé, pas de sauvegarde) ; l'événement redouté l'atteinte à éviter (fuite des certificats) ; le risque l'ensemble pondéré par P et G. Une menace exploite une vulnérabilité pour provoquer un événement redouté sur un actif.

**▼ Q16. Comment rédiger correctement un événement redouté ?**

[atteinte C / D / I / preuve] de [donnée ou actif] due à [menace] qui exploite [vulnérabilité], avec pour conséquence [impact]. Exemple : atteinte à la confidentialité des certificats médicaux due à un employé ou un attaquant exploitant un dossier partagé ouvert à tous, avec usurpation d'identité et atteinte à la vie privée des abonnés. Une phrase précise vaut mieux qu'un titre vague.

**▼ Q17. Sûreté ou sécurité : comment classer un incident ?**

On regarde l'intention. Panne de disque, erreur de manipulation, incendie, orage : sûreté. Intrusion, ransomware, vol de données : sécurité. Un fichier supprimé par erreur relève de la sûreté ; par vengeance, de la sécurité. Dans

les deux cas, si des DCP sont détruites, perdues ou divulguées, c'est une violation.

**▼ Q18. Matrice 5 × 5 ou 4 × 4 à l'examen ?**

Celle que l'énoncé impose ; même principe (C = P × G). La 5 × 5 est typique de la gestion de projet ; les 4 niveaux (négligeable, limité, important, maximal) sont ceux d'EBIOS RM et de la CNIL. Sans consigne, annoncer et définir l'échelle choisie, puis la respecter.

**▼ Q19. Comment fixe-t-on le seuil d'acceptabilité ?**

C'est une décision de l'organisation (direction, DPO, RSSI) selon l'appétence au risque, le secteur et les enjeux pour les personnes. Ici : ≥ 10 sur 25 pour la matrice 5 × 5. À l'examen, indiquer et justifier le seuil retenu.

**▼ Q20. Un risque très grave mais très peu probable peut-il être ignoré ?**

En gestion de projet, on « vit avec ». En protection des données, la gravité pour les personnes prime : une fuite de données de santé ou biométriques, même peu probable, impose des mesures renforcées et souvent une AIPD. On ne l'écarte que si la gravité pour les personnes est réellement faible.

**▼ Q21. Quelle différence entre risque, problème et faute ?**

Un risque est un événement futur possible ; un problème est un dommage déjà réalisé ; une faute est une erreur connue et non corrigée. « Le serveur pourrait être chiffré » : risque. « Le mot de passe admin est partagé et connu de tous » : problème et faute, à corriger immédiatement sans cotation.

**▼ Q22. Que signifie « accepter un risque » ? Peut-on tout accepter ?**

Décider par écrit, en connaissance de cause, de conserver un risque résiduel sous le seuil ; l'acceptation est documentée, validée par un responsable et réexaminée. Un risque intolérable ou une non-conformité légale (données sensibles sans base légale) doit être réduit, évité ou transféré.

**▼ Q23. L'AMDEC et la matrice P × G sont-elles équivalentes ?**

L'AMDEC ajoute l'indéterminabilité (probabilité de ne pas détecter l'incident à temps). Deux risques de même criticité P × G n'ont pas la même urgence si l'un est détecté tout de suite et l'autre passe inaperçu des mois : argument pour la journalisation et la détection (2e année).

**D. Méthode d'examen et lien avec le reste du programme**

**▼ Q24. Comment aborder l'analyse d'un document technique (schéma, tableau de risques, logs) ?**

Quatre temps : identifier le type de document et le contexte ; repérer les éléments critiques (données sensibles, accès, durées, flux) ; relever les incohérences (risque « faible » malgré une vulnérabilité élevée, absence de durée de conservation) ; recommander des mesures justifiées, en tableau constat → risque → mesure → principe RGPD ou critère.

**▼ Q25. Combien de mesures proposer et de quel type ?**

La pertinence et la justification comptent : viser 5 à 8 mesures prioritaires mêlant techniques (MFA, chiffrement, sauvegarde 3-2-1 hors ligne, journalisation, segmentation), organisationnelles (charte, habilitations, sensibilisation, contrats sous-traitants, registre) et physiques (accès aux locaux, destruction sécurisée), chacune reliée à un risque coté et à une couche de défense.

**▼ Q26. Prévention, protection, réparation : quelle différence ?**

La prévention réduit la probabilité (MFA, formation, mises à jour). La protection réduit l'impact (chiffrement, segmentation, sauvegarde). La réparation prévoit la réaction quand le problème est avéré (restauration, notification 72 h, communication). Un bon plan contient les deux volets, avec un responsable par risque.

**▼ Q27. Pourquoi 4 critères (preuve incluse) alors que beaucoup de cours parlent de CIA ?**

Confidentialité, intégrité, disponibilité sont le socle ; le support ajoute la preuve (non-répudiation), indispensable pour enquêter, sanctionner et démontrer sa conformité (art. 5.2). À l'examen, suivre le vocabulaire de l'énoncé ; en cas de doute, traiter les trois critères classiques et mentionner la preuve.

**▼ Q28. Comment ces deux séances préparent-elles la suite du programme ?**

Séance 3 : les outils Kali (nmap, nikto) découvrent des données exposées, ce qui repose sur la cartographie. Séances 4 à 6 : droits des personnes, notification et collecte de preuves reprennent preuve et traçabilité. 2e année : EBIOS RM approfondit la démarche ; DMZ, VLAN et Zero Trust reprennent la défense en profondeur.

**▼ Q29. Que faut-il absolument savoir par cœur ?**

(1) définition de la DCP et liste des données sensibles ; (2) les 7 principes et les 6 bases légales ; (3) la définition d'une violation et le délai de 72 h ; (4) les 4 critères et les 3 éléments de la preuve ; (5) C = P × G et l'idée de seuil ; (6) les 5 étapes de la gestion des risques ; (7) l'article 32 et l'article 35.